

ws02 강사 가이드

ws02 강사 가이드

2026년 생성형 AI 보안취약점 분석 교육 · 2회차 수강생 약 15~20명 · 작성일 2026-05-10

본 문서: 슬롯 1~5 전체 강사 진행 가이드 (시간 배분 · 강사 포인트 · 시간 조정 · 비상 대응)

하루 시간표 (실전 버전)

시간	슬롯	배정	내용
09:00 - 10:00	슬롯1	60분	LLM 보안 개요 + 위협 분류 (NIS · KISA)
10:00 - 10:10	휴식	10분	
10:10 - 11:10	슬롯2	60분	OWASP LLM Top 10 + 실제 사례
11:10 - 12:50	점심	100분	
12:50 - 14:20	슬롯3	90분	방어 대책 + 자동화 검증 + 🎮 Gandalf 챌린지
14:20 - 14:30	휴식	10분	
14:30 - 16:00	슬롯4	90분	🔍 Lab 1 — Garak 자동화 보안 스캐닝
16:00 - 16:10	휴식	10분	
16:10 - 17:30	슬롯5	80분	📄 Lab 2 — VectorDB · RAG 취약점
17:30	종료		

목표: 사전 설치/설정 완료 가정 → 슬롯3·4·5 실습 시간 충분히 확보 시간이 빠빠할 경우 각 슬롯 끝의 “시간 조정 포인트” 참고

강의 시작 전 체크리스트

- DEEPSEEK_API_KEY 사전 배포 확인
수강생 인당 1키 또는 강사 공유 키 – 배포 방법 결정
여분 키 2~3개 준비 (분실/오타 대비)
- 화면 공유 / 프로젝터 연결 확인
- 슬라이드 파일 열기 (5개)
ws02_slot1_nis_kisa.pptx (또는 _handout)
ws02_slot2_owasp_llm_top10.pptx
ws02_slot3_defense_lecture.pptx
ws02_Lab1_garak.pptx
ws02_Lab2_RAG_VectorDB.pptx
- Colab 노트북 미리 열기
nb01_garak.ipynb
nb02_rag_vectordb.ipynb
- gandalf.lakera.ai 브라우저 탭 열어두기 (Lv 1 화면)
- DeepSeek API 연결 테스트 완료 확인 (chat.completions 1번 호출)
- 백업 핫스팟 준비 (기관 네트워크 차단 대비)
- (옵션) cyberchef.io – base64 응답 디코딩 시연용

슬롯1 — LLM 보안 개요 + 위협 분류 (60분)

시간 배분

구간	시간	내용
도입	5분	사고 사례 — 삼성·딥시크·EchoLeak ★
위협 분류	25분	NIS T01-T15 4개 레이어
KISA 안내서	20분	3대 역할 (개발자·제공자·이용자)
마무리	10분	슬롯2 (OWASP) 와 연결

강사 포인트

- **EchoLeak (2025 후반)** 을 강력한 도입 사례로: Microsoft 365 Copilot 의 **zero-click prompt injection** — 이메일만 받아도 OneDrive · SharePoint · Teams 데이터 유출. “사용자가 클릭 한 번 안 해도 AI 가 공격자 도구가 됐다”
- **GitHub Copilot CVE-2025-53773 (CVSS 9.3)** — 프롬프트 인젝션으로 RCE, 수백만 개발자 영향
- **Cursor IDE CVE-2025-54135 / 54136** — MCP 신뢰 우회로 임의 명령 실행
- NIS T코드는 4 레이어 (입력 / 학습데이터 / 운영·인프라 / 공급망) 로 묶어서 외우기 쉽게
- KISA 안내서는 **2026.03 수정판** 기준으로 인용 + KISA 생성형 AI 개인정보 처리 안내서 (2025.08) 신규 발간 언급

시간 조정

- 시간 부족 시: T코드 일부 사례 슬라이드 빠르게 (T05·T11 등 운영 위협)
- 시간 남으면: 사고 사례 1~2개 추가 토론

슬롯2 — OWASP LLM Top 10 + 실제 사례 (60분)

시간 배분

구간	시간	내용
도입	5분	OWASP 가 왜 필요한가 (NIS 와 다른 시각)
Part 1	25분	LLM01-LLM10 핵심 요약
Part 2	20분	NIS × OWASP 매핑 + Agentic Top 10 (2026 신규)
마무리	10분	슬롯3 으로 전환 (<i>이론</i> → <i>운영 레이어</i>)

강사 포인트

- LLM01 프롬프트 인젝션 — **GitHub Copilot CVE-2025-53773 (CVSS 9.3)** 사례
- LLM07 시스템 프롬프트 유출 / LLM08 Vector & Embedding Weakness 는 슬롯5 Lab 2 와 연결
- **OWASP Top 10 for Agentic Applications (2026 신규)** 1장 — Agent Hijacking · Multi-Modal Injection · Memory Persistence Attacks 도입
- **MCP (Model Context Protocol) 보안 위기** 한 줄 강조:
 - Anthropic SDK 의 STDIO RCE — **Python · TypeScript · Java · Rust** 모든 언어 SDK 영향
 - 공개 MCP 서버 7,000개 중 **36.7% SSRF, 43% 1개 이상 취약점**
 - Tool poisoning 84% 성공률 (auto-approval 시)
 - → “에이전트 / 도구 호출 시대의 새 공격면”

시간 조정

- 시간 부족 시: 각 LLM 항목 1줄씩만, 매핑 표 강조
- 시간 남으면: ServiceNow second-order injection 같은 advanced 사례

슬롯3 — 방어 대책 + 자동화 검증 + 🎮 Gandalf 챌린지 (90분)

옵션 B: 강의 40분 + Gandalf 50분

상세 분당 가이드는 [slot3_instructor_guide.md](#) 참고

시간 배분

구간	시간	내용
오프닝	5분	흐름 안내
PART 1	20분	방어 4 레이어 (입력 / 출력 / 권한 / 모니터링)
PART 2	15분	수동 테스트의 한계 + Garak 소개 + vs promptfoo
PART 3	50분	🎮 Gandalf 챌린지

Gandalf 50분 세부

시간	내용
0:40-0:48	Lv 1 강사 시범 (5분) → 학생 따라
0:48-0:58	Lv 2~3 학생 자율
0:58-1:08	Lv 4 라이브 데모 5가지 ★
1:08-1:23	Lv 4~5+ 자율 도전
1:23-1:30	마무리 토론 + 슬롯4·5 예고

Lv 4 라이브 데모 5가지 ★

1. **역할극** (관리자/디버거 사칭)
2. **언어 전환** (영어/일본어) — 비코더 친화
3. **거꾸로 / 한 글자씩** (Spell backwards) — 비코더 친화
4. **간접 추출** (첫 글자, 길이)
5. **Agent / DAN** (“규칙 없는 AI” 페르소나)

강사 포인트

- 슬롯2 OWASP 매핑이 **위협별** 이라면, 여기는 **운영 레이어별** — 시각의 차이 강조
- T12 (모니터링) 이 핵심 — 빠지면 나머지 무용지물
- Gandalf 마무리에서 “*이걸 자동화하면 = Lab 1 Garak*”으로 자연스럽게

시간 조정

- 시간 부족 시: PART 2 도구 소개 압축 (Garak 자세한 부분은 Lab 1 으로)
 - 시간 남으면: 부록 — Gandalf Adventures, Gandalf the White, “내 회사 챗봇이라면” 토론
-

슬롯4 — Lab 1 · Garak 자동화 보안 스캐닝 (90분)

시간 배분

구간	시간	내용
Step 0	10분	환경 설정 (DEEPSEEK_API_KEY, garak 설치)
Step A	25분	첫 스캔 — 2종 프로브 (dan + Imrc)
Step B	20분	JSONL 결과 분석 + 디텍터별 취약률 시각화
Step C	25분	한국어 커스텀 프로브 작성
Step D	10분	AI for Security 다층 방어 개념

강사 포인트

- Step A 스캔 시간 (약 2~4분) 동안 다른 학생 진도 확인
- **Garak v0.14.1 (2026.04 출시)** 신규 기능:
 - **redesigned HTML 리포트** — 시각화 자동
 - JSON config 지원
 - **37+ 프로브 모듈**, DAN 변종 15+ (v6.0~11.0, STAN, DUDE, AntiDAN, Developer Mode)
- DAN 변종 다양성 — Gandalf Lv 4 의 패턴이 자동화된 형태
- LiteLLM 어댑터로 **Gemini · OpenAI · DeepSeek · 로컬 모델** 모두 동일 방식 — 실무 확장 강조

자주 발생하는 이슈

증상	대응
API key not valid	키 오타 확인, 여분 키
quota exceeded	동시 실행 분산 (5명씩 순차), 여분 키
garak 설치 느림	Colab 런타임 T4 GPU 사용 시 빠름
RateLimitError	DeepSeek RPM 한도 — 잠시 대기

시간 조정

- 시간 부족 시: Step C 커스텀 프로브 제출 표만 (작성은 시간 남는 학생만)
- 시간 남으면: 다른 프로브 카테고리 (encoding, latentinjection) 추가 시도

슬롯5 — Lab 2 · VectorDB · RAG 취약점 (80분)

시간 배분

구간	시간	내용
Step 0	10분	환경 설정 + RAG 인프라 구축 (FAISS + 헌법 PDF)
2A	12분	시스템 프롬프트 유출 (LLM07)
2B	18분	환각 — RAG 출처 인용 강제 (LLM09)
2C	18분	RAG 인젝션 — 오염 문서 (LLM01)
2D	12분	임베딩 역추출 — Jina 웹 데모 (T01·T06)
마무리	10분	종합 정리 + 다음 회차 예고

강사 포인트

- Step 0 RAG 인프라 구축은 **2~4분 소요** — 이때 강사 라이브 토크:
 - **Vector DB 노출 통계: 3,000+ 공개 인증 없는 서버** (Milvus · Weaviate · Chroma)
 - Swagger 문서까지 노출 → 공격자가 스키마·쿼리 알고 직접 공격
- 2B (환각) 가 가장 임팩트 — 모델이 그럴싸한 가짜 조문 생성하는 모습
- 2C 오염 문서 시나리오 + **신규 2C-3 Second-order injection 셀**:
 - **ServiceNow AI 비서 사례 (2025 후반)** — 저권한 에이전트가 오염 문서 통해 고권한 에이전트에게 요청 위임 → 권한 검사 우회
 - 응답 안에 `[ESCALATE: ...]` 같은 토큰이 끼어들어가는 모습 시연
- 2D Jina 데모는 **API 호출 0회** — 브라우저만으로

자주 발생하는 이슈

증상	대응
FAISS 인덱스 구축 4분 초과	강사가 미리 만든 인덱스 zip 배포 (Drive 링크)
헌법 PDF 다운로드 실패	강사 노트북에서 직접 첨부 — Colab 업로드
임베딩 모델 다운 느림	<code>BAAI/bge-m3</code> ~570MB — 첫 실행만 느림, 캐시 후 빠름
<code>gandalf.lakera.ai</code> 차단	(슬롯3 의 사후 사례) — 슬롯5 와는 무관

시간 조정

- 시간 부족 시: 2D Jina 데모는 화면 공유로 강사가 보여주기 (학생 시도 X)
- 시간 남으면: 부록 — 자유 공격 시간 (Vector DB 에 자기만의 오염 문서 삽입)

비상 대응 시나리오

상황	대응
API key not valid 오류	키 오타 확인, 안 되면 여분 키 배포
quota exceeded / RateLimit	여분 키 / 동시 실행 분산 (5명씩 순차)
gandalf.lakera.ai 차단	개인 핫스팟 안내 / 백업 강사 핫스팟
garak 설치 timeout	Colab 런타임 재시작 → 다시
FAISS 인덱스 4분 초과	미리 만든 인덱스 zip 배포 (Drive)
시간이 너무 남음	Gandalf Adventures / Gandalf the White / 자유 토론 (“내 회사 챗봇”)
17:30 넘길 것 같음	Lab 2 Step 2D 시연만 / Step C 종합표 생략
강사 노트북 다운	학생 한 명에게 화면 공유 부탁 (Colab 은 어차피 클라우드)

전체 시간 흐름 요약

09:00 ── 슬롯1 (60) – NIS·KISA
10:00 ── 휴식
10:10 ── 슬롯2 (60) – OWASP LLM Top 10
11:10 ── 점심
12:50 ── 슬롯3 (90) – 방어 + Gandalf
14:20 ── 휴식
14:30 ── 슬롯4 (90) – Lab 1 Garak
16:00 ── 휴식
16:10 ── 슬롯5 (80) – Lab 2 RAG/VectorDB
17:30 ── 종료

보안이 없으면, AI 도 없습니다.